

特集

弁護士 情報セキュリティ 規程

～弁護士に求められる
セキュリティ対策



Hisashi Nagira
柳楽 久司
(54期)
当会会員

【略歴】

2015年度 当会副会長

2019年～2021年 日弁連事務次長

2021年～ 日弁連「弁護士業務における情報セキュリティに
関するワーキンググループ」座長
当誌編集長

I

はじめに

2022年6月10日の日弁連定時総会において、「弁護士情報セキュリティ規程」（会規第117号）が成立した（以下「本規程」という）。本規程は「成立の日から起算して2年を超えない範囲内において理事会で定める日」に施行されることとなっており、各会員は、その施行日までに、自らの職務において取り扱う情報の「情報セキュリティを確保するための基本的な取扱方法」を定める必要がある（本規程3条2項）。筆者は、日弁連事務次長及び日弁連「弁護士業務における情報セキュリティに関するワーキンググループ」の座長として本規程の制定に関わってきたので、本稿では、施行日までに各会員が行うべき情報セキュリティ対

策のための体制整備に焦点を当てつつ、その前提として、本規程の背景や趣旨、このほど日弁連が会員に提示した「基本的な取扱方法」のサンプルの活用方法等について、若干の解説をしたい。もっとも、意見や感想、予測にわたる部分は全て筆者の私見であることをあらかじめお断りしておく。

II

制定の背景

① 民事裁判・刑事手続等のIT化の動き

2017年6月9日の閣議決定「未来投資戦略2017」を受けて同年10月に「裁判手続等のIT化検討会」が設置され、これを皮切りにその後いくつかの会義体と法制審議会での議論・検討を経て、2022年5月18日、民事訴訟手続のデジタル化等を内容とする改正民事訴訟法が第208回通常国会で成立した。この改正法は公布日（同月25日）から4年以内の政令で定める日までに段階的に施行され、完全施行されると、弁護士は訴状等を紙ではなくオンラインで提出しなければならない。

これと並行して、検討が遅れていた刑事手続についても、2021年3月に「刑事手続における情報通信技術の活用に関する検討会」が発足し、2022年3月に取りまとめを発表した。民事執行、民事保全、倒産、家事事件等についても手続のデジタル化の検討が進められており、今後、裁判に関わる全ての弁護士は、事件に関する情報を基本的に電子データとして保有することになる。

電子データは、複製が容易で、ひとたび流出すればインターネットを通じて無限に拡散され、かつ、インターネット上に半永久的に残存することになりかねないという特性があるほか、サイバー攻撃等による情報の漏えい、毀損、改ざん等の、紙媒体とは異なるリスクと常に隣り合わせにある。そうした問題意識から、前記民訴法改正の国会審議においても、裁判所や行政機関が十分なセキュリティ対策を講じるにしても、大小様々な規

模がある法律事務所のセキュリティ対策はどうするのかという疑問がなされ、政府参考人として出席した法務省の担当者が日弁連の動向を注視していると答弁する一幕があった。また、刑事手続IT化検討会においては、弁護人も含めた刑事手続全体の情報セキュリティをどのように確保するかが重大な関心事項となって正面から議論され、日弁連としての対応が急務となっていた。

② 既存の規程とガイドライン

情報セキュリティに関わる既存の関連規程として、職務基本規程18条がある。同条は「事件記録を保管し、又は廃棄するに際しては、秘密及びプライバシーに関する情報が漏れないように注意しなければならない」と定めているものの、この規定は情報漏えい以外のセキュリティリスク（後述）を全くカバーしておらず、これのみを根拠にして弁護士の情報セキュリティ対策を規律することはできない。弁護士法23条や職務基本規程23条についても同様である。

また、日弁連が2013年12月に制定した「弁護士情報セキュリティガイドライン」（2019年1月改訂。以下「現行ガイドライン」という。）^{※1}もあるが、これはあくまでも弁護士の情報セキュリティ対策の取組を支援することを目的として実践的な対策例を記述したものであり、弁護士が行うべき最低限の情報セキュリティ対策を規定したものでなければ、ガイドライン記載の取組を行うべき義務を課すものでもなかった。他方で、このような具体的な対策例に規範性を与えてしまうと、情報セキュリティ対策としてかえって実効性を失う可能性がある上に、個々の弁護士の業務に対する過度な介入になってしまうおそれもあった。このように、既存の関連規程やガイドラインをそのまま用いることや、あるいはそれを改正して対処することは困難であり、新たに本規程を制定することが必要となった。

※1 https://member.nichibenren.or.jp/gyomu/rinri_fatf/Information_security/securityguideline.html



「弁護士情報セキュリティ 規程」の概要

① 本規程の全体像

本規程は、全7か条のコンパクトな作りになっている。これは、弁護士一人ひとりの職務の独立性と執務環境の個別性に配慮した結果である。また、目まぐるしく変化する技術環境に機動的かつ柔軟に対応できるようにしておく必要もあり、そのため、会則に次ぐ上位規範である会規（会規の改正には日弁連の総会決議が必要となる。）にセキュリティ対策の具体的な措置を盛り込むようなことは避け、本規程では、ある程度時代や環境が変わっても通用すると思われるセキュリティ対策の大きな枠組みを提示することとした。

本規程は、第2条に「情報セキュリティ」と「取扱情報」の定義を置き、第3条で、各弁護士^{※2}において「取扱情報の情報セキュリティを確保するための基本的な取扱方法」（以下、カギ括弧つきで「基本的な取扱方法」という。）を策定すべき義務を定めている。

この「基本的な取扱方法」は、各弁護士がそれぞれの執務環境と業務態様に応じて意識的あるいは習慣的に行っている情報セキュリティ対策を「見える化」することで、人や機器の入れ替わり、技術環境の変化等にも対応しつつ不断に対策を講じてゆくための手がかりとしていただくものである。「基本的な取扱方法」の策定にあたっては、第4条以下の要素に配慮することが求められている。第4条以下の要素とは、安全管理措置の具体的内容（4条）、情報のライフサイクル管理の方法（5条）、点検及び改善の方法（6条）、漏えい等事故が発生した場合の対応の方法（7条）の4点である。

② 用語の定義（2条）

第2条（定義）

- 1 この規程において「情報セキュリティ」とは、次に掲げる特性が維持された状態をいう。
 - 一 機密性 情報に関して、アクセスを認められた者だけがアクセスできる特性をいう。
 - 二 完全性 情報が破壊、改ざん又は消去されていない特性をいう。
 - 三 可用性 情報へのアクセスを認められた者が、必要時に中断されることなく、情報にアクセスできる特性をいう。
- 2 この規程において「取扱情報」とは、弁護士等がその職務上取り扱う情報（紙、電磁的記録等その保管媒体を問わない。）をいう。ただし、前項各号に掲げる特性をいずれも維持する必要がないことが明らかな情報を除く。

（1）「情報セキュリティ」とは（2条1項）

本規程において「情報セキュリティ」とは、機密性（Confidentiality）、完全性（Integrity）、可用性（Availability）の3つの特性が維持された状態と定義されている。この3つの特性は、それぞれの頭文字を取って「情報セキュリティのCIA」とも呼ばれ、ISMS（情報セキュリティマネジメントシステム）定義規定の日本語版であるJIS Q27000や、政府機関等のサイバーセキュリティ対策のための統一基準群でも同様の定義が採用されている。なお、本規程の制定過程の議論では、弁護士への義務づけを伴う概念の定義は機密性に絞るべき（＝完全性や可用性は定義から外すべき）との意見も出されたが、弁護士の情報セキュリティは裁判所や検察庁といった国の機関とも密接に関係するものであるため、完全性や可用性も含め政府機関と同様の定義を採用した。

「**機密性**」とは、「情報に関して、アクセスを認められた者だけがアクセスできる特性」と定義されているが（1号）、これは要するに、見られてはならない人に見られてしまう状態になっていな

※2 弁護士法人、外国法事務弁護士、外国法事務弁護士法人及び弁護士・外国法事務弁護士共同法人を含む。以下同じ。

い、ということである。機密性の維持は、弁護士法23条、職務基本規程23条及び18条によって従前から弁護士に要請されている基本的な義務である。

「**完全性**」(2号)とは、情報が破壊されたり改ざんされたりすることなく、内容の正しい状態を維持していることである。「**可用性**」(3号)とは、その情報を使いたいときに使える状態を維持していることである。

情報セキュリティというと、とかく漏えいによる被害、すなわち機密性の維持に意識が向きがちであるが、裁判手続のIT化により提出や受領がオンライン経由でなされる制度が本格実施されると、完全性と可用性も重要な要素となってくる。例えば、自分のパソコンやネットワーク機器の不具合が原因で提出期限を徒過したような場合は手続上救済されない可能性があり、場合によっては弁護過誤にもなりかねないので、完全性や可用性の喪失がときに致命的な事態をもたらす可能性があることを考慮に入れておかなければならない。

(2)「取扱情報」とは(2条2項)

本規程では、情報セキュリティを確保すべき対象として「取扱情報」という用語が定義されている。事件類型にかかわらず、また、紙や電子といった保管媒体にかかわらず、さらには通話や会話といった媒体に固定化されていない情報も含め、弁護士が職務上取り扱う情報は基本的に全て「取扱情報」に含まれる。しかし、それだけでは範囲が広くなりすぎるので、雑誌・書籍や業者の宣伝チラシのような、移転や廃棄に際して特段の配慮を要しない性質の情報は「取扱情報」から除外することとした(同項但書)。



③「基本的な取扱方法」の策定(3条)

第3条(基本的な取扱方法の策定)

- 1 弁護士等は、その職務を行うに当たり、取扱情報の種類、性質等に応じた情報セキュリティに対する危険を把握するよう努めなければならない。
- 2 弁護士等は、前項の規定により把握した危険を踏まえ、所属する法律事務所等の規模及び業務の種類、態様等に応じて、取扱情報の情報セキュリティを確保するための基本的な取扱方法を定めなければならない。
- 3 弁護士等は、前項の規定により基本的な取扱方法を定めるに当たっては、次に掲げる事項に配慮するものとする。
 - 一 次条に規定する安全管理措置の具体的内容
 - 二 第5条に規定する情報のライフサイクル管理の方法
 - 三 第6条に規定する点検及び改善の方法
 - 四 第7条に規定する漏えい等事故が発生した場合の対応の方法

(1)危険の把握(3条1項)

情報セキュリティに対するリスクを把握することは、セキュリティ対策を講ずる上での出発点になる。もっとも、日々発見されては修正されるソフトウェアの脆弱性のような、技術面も含めたあらゆるリスクを完全に把握しきることは何人にとっても不可能であるため、危険の把握は努力義務とされている。

(2)「基本的な取扱方法」の策定(3条2項・3項)

個々の弁護士が抱える情報セキュリティリスクは、一人事務所、数人規模の共同事務所、数十人、数百人といった大規模事務所、あるいは複数の拠点を有する法人事務所等といった、事務所の規模や形態によって、また、取り扱う業務の性質によっても違いがある。こうした多種多様な執務環境にある弁護士の全てに共通する具体的な情報セキュリティ対策を一律に会規で規定することは困難で

あることから、本規程では各自のルールに盛り込むべき項目の枠組みだけを提示するにとどめ、各自が実践する情報セキュリティ対策の細目的な具体的事項については、各自の執務環境に応じた実効性あるルールを各自が定める制度設計となっている。

前述したとおり、「基本的な取扱方法」に盛り込むべき要素は第4条以下の4項目であるが、あくまでもこれは目安であり、実際の策定に当たっては、各自の執務環境におけるセキュリティリスクに応じて、実効性のあるルールを定める必要がある。

この「基本的な取扱方法」の策定義務は努力義務ではないので、本規程の施行日までに各自が何らかのものを定めなければならない。注意しなければならないのは、これは「一度定めたら終わり」という性質のものではないということである。セキュリティ対策は、技術の進歩、利用するサービスや使用機材の変化等に対応し、途切れることなく維持されていなければならない。そのため、一度定めた「基本的な取扱方法」も定期的に見直しを行い、随時アップデートを加えていく必要がある。

④ 安全管理措置(4条)

第4条(安全管理措置)

- 1 弁護士等は、自らの業務に係る取扱情報に関する情報セキュリティの責任者として、この規程に基づき、取扱情報の種類、性質等に応じた必要な管理体制を整備し、組織的、人的、物理的及び技術的な安全管理措置を講ずるものとする。
- 2 弁護士等は、事務職員、司法修習生その他の自らの職務に関連与させる者(以下「事務職員等」という。)に対して、情報セキュリティを確保するための必要な対策を講じさせなければならない。
- 3 弁護士等は、自ら又は事務職員等の情報セキュリティに対する知識を涵養し、高度情報化社会に伴う取扱情報の電子化に対応するため、研鑽及び教育に努めなければならない。

個人情報保護法ガイドライン通則編において、安全管理措置は、組織的安全管理措置、人的安全管理措置、物理的安全管理措置、技術的安全管理措置、の4つに分類されている。本規程もその枠組みに従っている。

まず、組織的安全管理措置の内容としては、一般に、組織体制の整備、規律に従った運用、取扱状況を確認する手段の整備、漏えい等の事案に対応する体制の整備、取扱状況の把握及び安全管理措置の見直し、といったものが挙げられる。「基本的な取扱方法」を定めてそれに従った運用をすることは、組織的安全管理措置の一環ということになる。

人的安全管理措置は、ヒューマンエラーによる事故を防ぐために行う従業者教育である。本条2項及び3項がそれに当たる。

物理的安全管理措置の内容としては、情報を取り扱う区域の管理、機器・電子媒体等の盗難・紛失の防止、廃棄時の漏えい防止、が挙げられる。

技術的安全管理措置の内容としては、パソコン・サーバー等へのアクセス制御、外部からの不正アクセスの防止等が挙げられる。

⑤ 情報のライフサイクル管理(5条)

第5条(情報のライフサイクル管理)

弁護士等は、取扱情報の作成、取得、保管、利用、提供、運搬、送信及び廃棄の各段階で、情報セキュリティが確保されるよう取扱情報を取り扱わなければならない。

情報のライフサイクル管理とは、情報の生成・取得、利用、保存、廃棄といった各フェーズにおける危険の違いに着目した管理の方法であり、「政府機関等の対策基準策定のためのガイドライン」でも採用されている。各フェーズにおける基本的な考え方は以下のとおりである。

- 生成・取得フェーズ：情報がその目的のために必要かつ十分に正しい内容を持つものとして生成・取得されること。

- 利用フェーズ：許された人だけがアクセスして、許された範囲の処理（閲覧、加工、編集、複製、移送等）だけ行うこと。
- 保存フェーズ：改ざんや消失、不正な持ち出しが起こらないよう、安全な場所・方法で保管すること。
- 廃棄フェーズ：他人に盗み見られることがないよう確実に消し去ること。

⑥ 点検及び改善(6条)

第6条(点検及び改善)

弁護士等は、取扱情報の情報セキュリティを持続的に確保するため、法改正、技術的進歩その他社会環境の変化及び自らの職務遂行体制の変化に応じて、基本的な取扱方法に定める安全管理措置及び情報のライフサイクル管理の方法が適切に機能しているかを点検し、必要に応じてこれらに改善を加えるよう努めなければならない。

技術の発展は日進月歩であり、情報セキュリティに対する脅威も日々変化する。業務に使用する機器等についても、年月の経過に伴う物理的・機能的劣化を免れることはできない。情報セキュリティ対策はいわば「終わりのなき戦い」であり、常にアップデートし続ける必要がある。

点検及び改善は形式的・画一的なものではなく、それぞれの執務環境に応じて情報漏えい等の危険が高い項目を集中して点検する等、リスク評価を前提とした点検計画の策定と実行が必要である。「基本的な取扱方法」に定めた安全管理措置や情報のライフサイクル管理が実際に運用されているか、事務所のサーバーや各自のパソコン、ソフトウェアの更新状況等を点検し、古い機器の入れ替え等の改善すべき項目が見つかった場合には必要に応じて改善を行うほか、「基本的な取扱方法」そのものについても見直しが必要か検討する。

点検はスケジュールが重要である。気がつけば3年などはあっという間になってしまうので、「毎年4月の第1週」などとあらかじめ時期を決めて、予定表に書き込んでおくといよい。

⑦ 漏えい等事故が 発生した場合の対応(7条)

第7条(漏えい等事故が発生した場合の対応)

弁護士等は、取扱情報の漏えい、滅失、毀損等の事故が発生した場合には、その影響範囲の把握に努め、必要に応じ、被害の拡大防止、原因調査、再発防止策の検討その他の措置を講じなければならない。

十分な対策を取っていたとしても、事故は起こりうる。事故発生時の対応手順をあらかじめ定めておくことは、組織的安全管理措置の一環でもある。ここで、情報セキュリティが破られ、あるいは脅かされる場面については、「事案」（あるいは「事象」）と「事故」とに分けて考えられており、本条は比較的軽微なセキュリティ「事案」については対象とせず、重大な「事故」発生時の対応義務について定めている。

なお、個人情報保護法ガイドライン通則編においては、漏えい等事案が発覚した場合の措置として、「①事業者内部における報告及び被害の拡大防止、②事実関係の調査及び原因の究明、③影響範囲の特定、④再発防止策の検討及び実施、⑤個人情報保護委員会への報告及び本人への通知」の5点が挙げられており、漏えい等したものが個人データであった場合は、個人情報保護委員会への報告が義務付けられている。

IV 「基本的な取扱方法」 策定のポイント

① 策定の前提

(1) 事務所単位で策定

本規程は、弁護士全て（弁護士法人等を含む）を名宛人としており、「基本的な取扱方法」の策定義務は弁護士一人ひとりに課されている。しか

しながら、実際には、複数の弁護士が所属する事務所では、事務所という物理的な空間や、プリンター・FAX等の複合機、サーバー、ルーター等のネットワーク機器、各種ソフトウェア、外部サービスの契約、さらには事務職員やマニュアルといった人的資源を所属弁護士が共用しており、当該執務環境における情報セキュリティリスクは共通であることが多い。そのような事務所においては、事務所として1個の「基本的な取扱方法」を定め、これをもって所属弁護士各自の「基本的な取扱方法」として扱うのが現実的である。

複数の拠点を持つ弁護士法人の場合、法人として1個の「基本的な取扱方法」を定め、各拠点で共通のものを使用するということも考えられるし、基本的な部分は共通としつつ一部を拠点ごとにカスタマイズしたものを使用するという方法も考えられる。

(2) 誰が作るか

弁護士が一人の事務所の場合、「基本的な取扱方法」はその弁護士が自分で作るしかない。あるいは、パソコン周りは事務職員に教えてもらっているという場合は、その事務職員の協力のもと、自らの判断で各措置の採否を決定していくことになる。あくまでも弁護士業務における情報セキュリティ確保の責任者は、事務職員ではなく弁護士だからである。

弁護士が複数いる事務所の場合は、事実上、メンバーの誰か（特定の弁護士や事務職員）が事務所のパソコンやネットワーク関係の管理を行う役割を担っているという事務所が多いのではないかとと思われる。「自分はパソコンのことはよく分からない。うちの事務所にはパソコンに詳しいイソ弁（事務職員）がいるので、パソコン周りのことは全部そのイソ弁（事務職員）に任せている」というような人もいるだろう。そのような事務所の場合は、その「詳しい人」がその事務所の「基本的な取扱方法」の策定を主導することになると思われる。

業務の効率性を考えれば、こうした在り方自体

は否定されるべきものではない。かといって、全部誰かにお任せで自分は関係ないというスタンスでは、そのような意識の持ち主が「人間のセキュリティホール」となってセキュリティリスクを高めることになりかねない。ヒューマンエラーを防ぐため、あるいは基本的な安全管理を怠ったり、初歩的な罠に引っかかったりして漏えい等事故を起こさないように、自分の執務環境や、世間で流行しているサイバー攻撃の手法等について、ある程度の現状把握はしておく必要がある。そのためには「基本的な取扱方法」の策定を主導する人を含む事務所の構成メンバーと打合せの場を持つなどして、できるだけ認識の共有に努めていただく必要がある。

(3) インハウスの場合

企業や団体に所属する弁護士は、所属組織が提供する機器やネットワークを使用することが多いと考えられ、所属組織がセキュリティポリシーを定めている場合は、所属組織が定めるポリシーをもって当該インハウス弁護士の「基本的な取扱方法」として扱うことを想定している。したがって、所属組織の定めるセキュリティポリシーが十分である場合は、弁護士が別途「基本的な取扱方法」を定める必要はない。もっとも、所属組織がそもそもセキュリティポリシーを定めていない場合や、ポリシー自体はあるものの内容が不十分であるような場合は、別途自分で「基本的な取扱方法」を定めるか、あるいは組織のポリシーの変更を促すこと等が求められる。また、所属組織の業務に含まれない別個の業務を遂行し、その際に独自の機器やネットワークを使用するような場合は、所属組織のポリシーとは別に、独自の「基本的な取扱方法」を定める必要が生じることもありうる。

② 典型的なセキュリティリスクを知る

(1) 情報漏えいのパターン

実効性のある対策を講ずるためには、まず、どういった点に気をつければよいか、すなわち世間

ではどういう形態でセキュリティ事故が起きているかを知るところから始めるとよい。

ア 紛失・盗難

IT化以前からある典型的な漏えいのパターンとして、秘密情報を含む有体物を紛失したり盗難されたりするパターンがある。IT化以前であれば紙媒体の事件記録の紛失や盗難のダメージは限定的なものではあったが、今では紙媒体の情報でもスキャンや写真撮影で容易に電子データ化されるので、拡散範囲は無限定かつ永続的なものになりうる。少し前にも、自治体から委託を受けていた業者が住民の個人情報格納されたUSBメモリを紛失するという事件が報道されていたが、電子データは利用と複製、転送の容易性はさらに高まるので、被害が甚大なものとなりうる。紙媒体の事件記録、USBメモリなどの記憶媒体、ノートパソコンやスマートフォンに格納された秘密情報が紛失や盗難によって悪意のある第三者に渡ることがないように、紛失と盗難を予防するための「仕組み」を考えておくことが重要である。

イ 誤送信・誤交付

これもIT化以前からあるものではあるが、例えばFAXの誤送信が典型例である。ほかにも、郵送物の封入間違いや交付時の誤りによって、本来見られてはならない情報が間違っただ第三者に見られてしまうということが起こりうる。用紙節約のために裏紙を利用して印刷していたものを、面を間違えてFAXしたことにより、裏面の情報が相手にFAXされたという事案や、記録返却の際にファイリングしていた裏紙の別事件の情報が他人に渡ってしまったという事例も現実には起こっている。メールの誤送信（宛先間違い）や、添付するファイルのミスなどで、本来送るべきではない相手に関係人の秘密情報が渡ってしまうようなこともある。このようなヒューマンエラーを可及的に防ぐルーチンを取り入れておく必要がある。

ウ インターネットを通じた誤公開

限られたメンバーの間でだけ共有していたつもりだったのに、利用サービスの設定を誤っていたために全世界に公開されていたというパターンで

ある。現行ガイドラインが制定される契機となったメーリングリスト公開事件では、事務所内部で運用していたメーリングリストの設定の誤りによって、そこでのメールのやりとりがインターネット上の誰でも見られる状態になっていた。

エ 不正プログラム（マルウェア）

マルウェア（malware）とは、不正かつ有害な動作をさせる意図で作成された悪意のあるプログラムやソフトウェアを総称するものであり、いわゆるコンピュータ・ウイルスが代表的なものである。マルウェアには様々な形態のものがあり、日々新たなマルウェアが発見されている。

例えば2014年に初めて報告された「Emotet（エモテット）」は感染力・拡散力が非常に強いマルウェアであり、流行と収束を繰り返しながら現在もなお広い範囲に被害をもたらしている。メールの添付ファイルを開いて一定の操作をしたり、メールに記載されたURLをクリックしたりすることで感染する。感染すると、端末やブラウザに保存されたパスワード等の認証情報が窃取されたり、メール本文とアドレス帳の情報が窃取されて感染を拡散するメールの送信に悪用されたりする。さらにたちが悪いことに、これに感染するとほかのマルウェアに次々と感染させられる。このようなマルウェアに感染しないようにするためには、ウイルス対策ソフトを入れておくことは最低限必要であるが、それを入れていれば万全というわけではない。身に覚えのないメールの添付ファイルは開かない、添付ファイルを開いたときに見慣れない警告が表示されたような場合は処理を中断してファイルを閉じる、メールに記載されたURLを安易にクリックしないなどといった、基本的なリテラシーを身につけておく必要がある。近時、不正メールの偽装方法がどんどん巧妙化しているので、少しでも怪しいと思ったら開かないといった対応が必要である。

オ 不正アクセス

昨今はインターネット上のあらゆるサービスでIDとパスワードの設定が要求されるが、面倒がってIDとパスワードを使い回していたり、容易に

推測されるようなパスワードを使っていたりすると、悪意ある攻撃者に不正にログインされて非公開情報を窃取されたりアカウントを乗っ取られたりする。

特に、業務に使用しているメールとクラウドストレージサービスのパスワードが突破されるとほぼ回復不能なダメージを受けることになるので、メールとクラウドのパスワードは特に複雑なものにして厳重に管理する必要がある。

カ 不適切な廃棄

紙媒体の事件記録を一般ゴミとして廃棄すると、それがどのような者に拾得されるかは分からない。また、パソコンやスマートフォンを廃棄・リサイクルする場合も、単に初期化するだけでは容易にデータを復元されてしまうので、廃棄・リサイクルの際には専用ソフトを使用する等して中のデータが復元されないよう十分な対策を講ずる必要がある。

(2) 漏えい以外の事故のパターン

ア 情報の改ざん

情報の完全性が喪失させられるパターンである。実際にあった例としては、法律事務所や弁護士会のウェブサイトが改ざんされたというケースが複数ある。これはウェブサーバーに侵入された例であるが、侵入される場所次第では、保管している事件記録のデータが改ざんされるということも起こりうる。

イ ランサムウェアによるデータのロック

ランサムウェア (ransomware) とは、感染した端末をパスワードでシステムロック、又はファイルやフォルダを暗号化するなどしてコンピュータを利用できない状態 (人質) にして、元の状態に戻すことと引き換えに身代金 (金銭や暗号資産) を要求するマルウェアのことである。データのロックだけではなく、データを窃取したうえ対価を支払わなければ当該データを公開すると脅して金銭等を要求する二重恐喝 (ダブルエクストーション) という手口もある。海外では数年前から医療機関や法律事務所に対するランサムウェアの

攻撃が多数報告されており、国内でも医療機関が攻撃を受けて長期間業務に支障が生じたほか、法律事務所でも被害事例がある。裁判のIT化により今後裁判に関わる全ての弁護士が事件記録を電子データで保有することになれば、国内の法律事務所に対する攻撃が増加することが予想されるため、対策が急務である。

ウ 機器の故障・記憶媒体の劣化による

データの喪失

悪意あるサイバー攻撃を受けなくとも、平時において起こりうる事象として、業務に使用しているパソコンが故障したり、記憶媒体が劣化して中のデータを使用できなくなったりするという可能性は常に想定しておかなければならない。端末の復旧やデータの復元ができず、バックアップも取っていないければ、データは失われ、完全性と可用性を喪失した状態となる。

前述したように、民事・刑事の裁判が完全IT化されたとき、完全性と可用性の喪失は依頼者と弁護士に深刻な被害をもたらしかねない。パソコンを含む電子機器は、いつどのようなタイミングで故障するか予測ができないので、故障の際の障害を最小限に食い止められるよう、常に備えておく必要がある。

③ 日弁連の「基本的な取扱方法」サンプル

(1) サンプルの性質

本年3月8日、日弁連が会員に向けて「基本的な取扱方法」のサンプルを公表した。現在、会員専用ホームページで見ることができる (一般公開はしていない)。各項目の注釈付きの Word ファイルと、本文のみの編集・コピー用 Word ファイルがダウンロード可能である^{※3}。

ただし、このサンプルは、あくまでもサンプルであって、必ずしも全ての弁護士がこれに準拠して「基本的な取扱方法」を定めなければならないという性質のものではなく、全く独自に「基本的な取扱方法」を定めても一向に構わない。また、

※3 https://member.nichibenren.or.jp/gyomu/rinri_fatf/Information_security/security_basic_handling_method.html

このサンプルは、全弁護士に共通のルールや最低基準を示すものではなく、サンプルに記載された手法の遵守が求められたり、あるいは懲戒手続の基準とされたりすることも想定していない。

「基本的な取扱方法」の策定に当たってこのサンプルをどのように利用するかは会員の自由であるが、サンプルには部分的に複数の選択肢を例示している箇所があるので、これを単純に全文コピー＆ペーストしただけでは利用できないようになっている。サンプルをベースに「基本的な取扱方法」を策定する場合でも、必ず自分の執務環境に応じたカスタマイズを加えることが必須である。

(2) サンプルの構成

サンプルには、「弁護士1人の法律事務所」用と「弁護士複数の法律事務所」用の2種類が用意されているが、両者に大きな違いはなく、目次は以下のように共通のものとなっている。

- 1 用語
- 2 安全管理措置
 - (1) 組織的な安全管理措置
 - (2) 人的な安全管理措置
 - (3) 物理的な安全管理措置
 - (4) 技術的な安全管理措置
 - ア アカウント管理及びアクセス制御
 - イ ソフトウェア及びサービス
 - ウ ハードウェア
- 3 情報のライフサイクル管理
 - (1) 情報の受領・取得
 - ア 受領・取得(総論)
 - イ 受領(FAX)
 - ウ 受領(郵便・宅配便)
 - エ 受領(電子メール)
 - オ 取得(撮影、録音又は録画)
 - (2) 情報の保管
 - ア 保管(紙媒体記録等)
 - イ 保管(データ)
 - ウ 保管(モバイル機器)
 - エ 保管(外部サービス)

(3) 情報の発信・交付等

- ア 発信・交付(総論)
- イ 発信(FAX)
- ウ 発信(電子メール等)
- エ 発信(SNS等)
- オ 交付
- カ マスキング

(4) 情報の持出し・複製

- ア 持出し
- イ 複製(紙媒体記録等のデータ化を含む。)

(5) 情報の廃棄・返還

- ア 廃棄(総論)
- イ 廃棄(紙媒体記録等)
- ウ 廃棄(データ)
- エ 返還

(6) 会議・期日出席

- ア 総論
- イ 期日
- ウ ウェブ会議

4 点検及び改善

5 漏えい等事故が発生した場合の対応

前述したように本規程3条3項が「基本的な取扱方法」の策定に当たって配慮すべき4つの要素を定めているので、このサンプルもそれに沿った構成になっている。したがって、このサンプルの構成に沿って自らの執務環境を点検していけば、基本的な項目についての抜け漏れは防げるものと思われる。なお、繰り返しになるが、ここに挙げられている項目を必ず全て網羅しなければならないというのではなく、各自の執務環境や業務の態様に応じて必要なものを取捨選択すればよい。もちろんサンプルが挙げていない、より高度な対策を既に行っているような場合は、それを自らの「基本的な取扱方法」に盛り込めばよい。

④ 自分の執務環境の現状を把握する

「基本的な取扱方法」を策定するにあたって何より重要なのは、自身の執務環境の現状を把握することである。「誰が」「どのような情報を」「いつ」「どこで」「どのように」取り扱っているか、少し

振り返ってみるだけでも色々と発見がある。

(1) 情報の保管状況の確認

まずチェックしてもらいたいのは、どのような情報が、どこにどのように保管されているかの洗い出しである。継続中の事件の情報、終了した事件の情報、事件以外の守秘すべき情報（顧客や関係者の連絡先情報、事務所の経理情報など）、会務の情報やその他の情報が、それぞれ、紙媒体ではどこに存在し、電子データとしてはどこに存在し、ということ一度書き出してみるとよい。電子データとして保管している場合は、それがパソコン自体（ローカル）に保存されているのか、事務所のファイルサーバーに保存されているのか、クラウドストレージに保存されているのか、あるいはそれらが併用されているのか、様々な保存場所がありうる。一時的なデータ移動のために使用したUSBメモリの中に残っている情報などもあるかもしれない。このような「忘れていたデータ」は危険なので、そのような小さな媒体に保存されたままになっているデータがないかも点検する必要がある。

(2) パソコン周りのチェック

また、業務で使用しているパソコンやネットワーク機器をチェックすることも重要である。例えば、自分で使っているパソコンでさえ、それをいつ購入したかを聞かれて即答できる人は少ないのではないだろうか。事務所のほかのメンバー（弁護士、事務職員）が使っているパソコンはどうか。それぞれのパソコンのOS(Windowsなど)のバージョンはどうなっているか。ウイルス対策ソフトは個別に入れているか、事務所で共通のものを入れているか。事務所のネットワーク環境はどうなっているか。ルーターの購入時期はいつか。事務所でWi-Fiの電波を飛ばしているか。Wi-Fiのセキュリティ方式はWEPか、WPAか、WPA2か、パスワードは何桁になっているかなど、パソコンやネットワーク機器だけでも点検すべき項目は多い。業者に委託している場合は、年に1回などと

定めた点検の時期に、業者に連絡して事務所の現状を確認してもらうとよいだろう。

(3) 事務所外の執務環境も

事務所内の環境だけでなく、自宅を含めた事務所以外の場所で執務するときの環境や、移動中の運搬方法なども振り返ってみる必要がある。自宅のパソコンやインターネット環境はどうか。移動中や外出先で使用する機器の安全性はどうか、といった点も考えておく必要がある。

⑤ 事務所としてのルールの策定

ある程度現状把握ができたところで、事務所としてのルールを考えていくことになる。事務所の現状にルールの側を寄せていく項目もあれば、逆に、高めのルールを設定して事務所の運用をそれに合わせて変えていくという項目もあるだろう。そのあたりの対応は要素ごとに違っていて構わない。

セキュリティ対策というのは業務の効率性とトレードオフの関係にあるので、やみくもに高いセキュリティレベルを求めるというのも非現実的である。費用対効果や業務の効率性への影響を考慮しながら、現実的なレベルで折り合いをつける必要がある。この「現実的なレベル」は、顧客との関係性や、個々の場面で取り扱う情報の性質によっても変動しうるので、各事務所で定めるルールも過度に硬直的なものとするのではなく、一定の柔軟性を持たせたルール設定が必要なこともありうる。

一例として、日弁連理事会や意見照会の場面で特に多く意見が寄せられたのが、メールの添付ファイルをどうするか、という問題である。日本では、パスワード付きzipファイルをメール添付ファイルで送信し、次のメールでzipファイルの解凍パスワードを送るという方法（いわゆる「PPAP」と呼ばれるファイルの送り方）が広く普及していたが、この方式はセキュリティ対策の観点からも受け取る側の利便性の観点からも適切では

ないとして、政府は2020年11月にこの方式を廃止すると発表した^{※4}。これを受け、民間でもこの方式を廃止する動きが広まっている。代替策として、クラウドのファイル転送サービスの利用が増えているが、この方法も万能のものではない。相手の環境によってはメールに記載したURLからのファイルダウンロードができず、この方法でのファイルの受渡しができないこともある。そのような場合は、相手の状況に応じて、以前のようなメール添付の方法でファイルを送ることもある。そのため、日弁連サンプルにおいても、メール送信の場面のルールについては【案1】から【案3】までの3通りの案を用意して、適宜選択していただくことにしている。

いずれにせよ重要なのは、「基本的な取扱方法」においてある行為を一律に禁止してそのルールを墨守するということではない。相手の環境やその時の状況に応じてセキュリティレベルを緩和した行動を取る場合でも、そうする理由を意識しながら行動するということである。

V 参考情報

最後に、情報セキュリティの意識を高めるために、役に立つ参考情報を2つほど紹介しておきたい。

■中小企業の情報セキュリティ対策ガイドライン^{※5} (IPA)



付録1の「情報セキュリティ5か条」は有名。

付録3の「情報セキュリティ自社診断」は一度やってみるとよい。チェック項目を斜め読みするだけでも、意識すべきポイントが見えるようになる。

■インターネットの安全・安心ハンドブック^{※6} (NISC)



2023年1月に刊行されたver5.00では、NISCとIPAが共同で提唱する「サイバーセキュリティ対策」が9箇条になり、内容も刷新されている。「多要素認証を利用しよう」、「メールの添付ファイルや本文中のリンクに注意しよう」といった、より具体的な対策が記載されるようになった。バックアップの重要性についても触れている。バックアップの考え方については、このハンドブックの本文42・43ページをご一読されたい。

VI 終わりに

裁判IT化の本格化を控え、弁護士には、以前にも増して電子データの適切な取扱いが求められるようになってきている。今後、情報セキュリティ対策は、弁護士の「業務のクオリティ」の重要な一要素として利用者による評価の対象となってくると思われる。こう言っている筆者自身の執務環境を振り返ると甚だ心許ないのではあるが、会員各位におかれても、是非自らの業務の質を高めるのだという意識をもって、情報セキュリティ対策に取り組んでいただきたい。

※4 平井内閣府特命担当大臣(当時)記者会見要旨 令和2年11月24日 https://www.cao.go.jp/minister/2009_t_hirai/kaiken/20201124kaiken.html

※5 <https://www.ipa.go.jp/security/keihatsu/sme/guideline/index.html> ※6 <https://security-portal.nisc.go.jp/guidance/pdf/handbook/handbook-all.pdf>